

PRD Bot Telegram Ayong Store

Sep 29, 2026 · @Khairul Huda

Ringkasan

Ayong Store akan punya bot Telegram publik. Siapa pun bisa membuka bot. Hanya admin dan owner yang sudah login bisa menjalankan command operasional.

Bot ini memindahkan lima pekerjaan harian dari panel web ke chat: login, unduh laporan, konfirmasi pembayaran, notifikasi pesanan baru dengan bukti bayar, dan buka/tutup toko.

Kondisi saat ini (dari repo `topup-hgi`):

- Aplikasi berjalan di CodeIgniter 4, PHP 8.2, MySQL.
- Pembayaran manual lewat bank atau QRIS. Customer mengunggah bukti, admin memverifikasi di `/admin/pesanan/{id}`.
- Status pesanan: `menunggu_pembayaran` → `menunggu_verifikasi` → `diproses` → `selesai`.
- Notifikasi ke admin memakai WhatsApp (Wablas). Admin harus membuka panel web untuk melihat bukti bayar.
- Buka/tutup toko memakai setting `maintenance` di tabel `store_settings`.
- Laporan penjualan hanya bisa diakses role `owner` di panel web.

Tujuan dan Metrik

Tujuan

1. Admin bisa memverifikasi pembayaran tanpa membuka panel web.
2. Admin menerima detail pesanan dan foto bukti bayar begitu customer mengunggahnya.
3. Owner dan admin bisa mengunduh laporan penjualan dari chat.
4. Owner bisa menutup dan membuka toko dalam satu command.

Bukan tujuan (fase ini)

- Customer tidak bisa checkout lewat bot.
- Bot tidak menggantikan panel admin untuk CRUD produk, voucher, dan banner.
- Bot tidak mengurus workflow bongkar kartu.

Metrik keberhasilan

Metrik	Target
Waktu dari upload bukti sampai notifikasi admin	< 10 detik
Median waktu upload bukti sampai verifikasi	Turun 50% dari baseline 30 hari sebelum rilis
Verifikasi lewat bot	≥ 70% dari semua verifikasi, 30 hari setelah rilis
Aksi bot tanpa login yang berhasil	0

Pengguna dan Peran

Bot memakai role yang sudah ada di tabel `admins`. Tidak ada role baru.

Peran	Siapa	Akses di bot
Tamu	Siapa pun yang membuka bot	<code>/start</code> , <code>/help</code> , <code>/login</code>
Admin	Akun <code>admins</code> dengan role <code>admin</code>	Laporan, konfirmasi pembayaran, notifikasi pesanan, buka/tutup toko
Owner	Akun <code>admins</code> dengan role <code>owner</code>	Semua akses admin, ditambah daftar sesi login bot

Catatan: panel web saat ini membatasi laporan untuk owner saja. PRD ini membuka laporan untuk admin di bot sesuai permintaan. Panel web ikut disesuaikan agar aturannya sama.

Kebutuhan Fungsional

F1. Login admin

1. User mengetik `/login`. Bot meminta email akun admin, lalu password.
2. Bot mencocokkan kredensial dengan tabel `admins` memakai `password_verify`. Akun harus `is_active = 1`.
3. Jika cocok, bot menyimpan sesi: `telegram_user_id`, `admin_id`, waktu login, waktu kedaluwarsa.
4. Bot langsung menghapus pesan yang berisi password dari chat.
5. Login hanya boleh di private chat. Di grup, bot menolak dan meminta user pindah ke chat pribadi.

6. `/logout` menghapus sesi. Sesi otomatis habis setelah 7 hari tanpa aktivitas.
7. Gagal login 5 kali dalam 15 menit mengunci `telegram_user_id` selama 15 menit.
8. Jika akun dinonaktifkan atau password diganti di web, semua sesi bot akun itu ikut berakhir.

Catatan: tabel `admins` tidak punya kolom username. Login memakai email sebagai username.

F2. Unduh laporan penjualan

- `/laporan` menampilkan tombol pilihan: Hari ini, 7 hari, Bulan ini, Bulan lalu, Pilih bulan.
- Bot mengirim file Excel (.xlsx) sebagai dokumen. Opsi `/laporan pdf` mengirim PDF.
- Isi laporan sama dengan halaman `/admin/laporan` : jumlah pesanan, omzet, diskon, produk terlaris, rincian per hari.
- Hanya pesanan berstatus `diproses` dan `selesai` yang dihitung omzet.
- Setiap unduhan tercatat di `activity_logs` dengan aksi `telegram_unduh_laporan`.

F3. Konfirmasi pembayaran

- `/pending` menampilkan daftar pesanan berstatus `menunggu_verifikasi`, paling lama di atas, maksimal 10.
- Setiap pesanan punya tombol **Verifikasi** dan **Tolak**.
- Verifikasi memanggil `OrderModel::verifyPayment`. Status berubah ke `diproses`.
- Tolak meminta alasan (maksimal 500 karakter), lalu memanggil `OrderModel::rejectPayment`. Status kembali ke `menunggu_pembayaran`.
- Update memakai kondisi status, jadi dua admin yang menekan tombol bersamaan tidak menghasilkan aksi ganda. Admin kedua mendapat pesan "Pesanan sudah diproses oleh <nama admin>".
- `/selesai <invoice>` menandai pesanan `diproses` menjadi `selesai` dan memicu WhatsApp ke customer.
- Semua aksi tercatat di `activity_logs` dengan nama admin dan sumber `telegram`.

F4. Notifikasi pesanan dan bukti bayar

- Saat customer berhasil mengunggah bukti, sistem mengirim ke semua admin dan owner yang sudah login dan mengaktifkan notifikasi.
- Isi pesan: nomor invoice, produk, nominal, total bayar, diskon, kanal pembayaran, waktu upload, ID game dan WhatsApp customer (lengkap, karena penerimanya admin).
- Foto bukti dikirim sebagai foto, bukan tautan publik. File tetap di `writable/uploads/payment-proofs/`.

- Pesan notifikasi membawa tombol **Verifikasi** dan **Tolak** yang sama dengan F3.
- Setelah satu admin bertindak, bot mengedit pesan di chat admin lain menjadi "Sudah diverifikasi oleh <nama>".
- `/notif on` dan `/notif off` mengatur penerimaan notifikasi per admin.
- Pengiriman memakai antrean. Gagal kirim dicoba ulang 3 kali. Upload bukti customer tidak boleh gagal karena Telegram gagal.

F5. Buka dan tutup toko

- `/tutup [alasan]` mengubah setting `maintenance` menjadi `1`. Halaman publik menampilkan halaman maintenance. Panel admin tetap bisa diakses.
- `/buka` mengubah `maintenance` menjadi `0`.
- `/status` menampilkan status toko, siapa yang terakhir mengubah, dan kapan.
- Bot meminta konfirmasi lewat tombol sebelum menutup toko.
- Setiap perubahan dikirim ke semua admin yang login dan tercatat di `activity_logs`.

Daftar Command

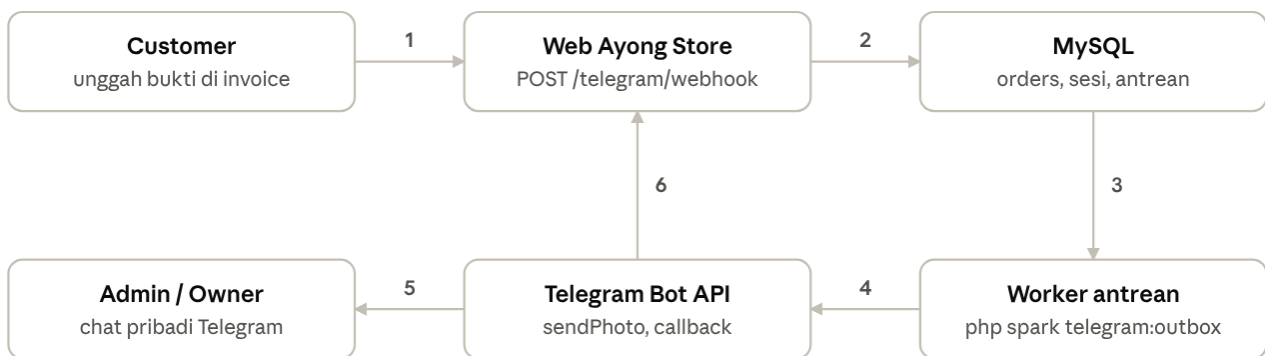
Command	Fungsi	Tamu	Admin	Owner
<code>/start</code>	Sapaan dan info toko	Ya	Ya	Ya
<code>/help</code>	Daftar command sesuai role	Ya	Ya	Ya
<code>/login</code>	Login dengan email dan password	Ya	Ya	Ya
<code>/logout</code>	Akhiri sesi bot	Tidak	Ya	Ya
<code>/laporan [pdf]</code>	Unduh laporan penjualan	Tidak	Ya	Ya
<code>/pending</code>	Daftar pesanan menunggu verifikasi	Tidak	Ya	Ya
<code>/pesanan <invoice></code>	Detail satu pesanan dan bukti bayar	Tidak	Ya	Ya
<code>/selesai <invoice></code>	Tandai pesanan selesai	Tidak	Ya	Ya
<code>/notif on off</code>	Atur notifikasi pesanan baru	Tidak	Ya	Ya
<code>/tutup [alasan]</code>	Tutup toko (maintenance on)	Tidak	Ya	Ya
<code>/buka</code>	Buka toko (maintenance off)	Tidak	Ya	Ya
<code>/status</code>	Status toko saat ini	Tidak	Ya	Ya
<code>/sesi</code>	Lihat dan cabut sesi bot semua admin	Tidak	Tidak	Ya

Tamu yang mengetik command admin mendapat balasan "Silakan /login terlebih dahulu". Bot tidak memberi tahu apakah command itu ada.

Arsitektur Teknis

Bot hidup di dalam aplikasi CodeIgniter yang sama. Tidak ada server baru. Bot memakai webhook Telegram, bukan polling, karena hosting saat ini memakai FTP dan shared hosting.

Notifikasi keluar lewat antrean, aksi admin masuk lewat webhook



alur notifikasi dan verifikasi · 6 langkah

1. Customer mengunggah bukti bayar.
2. Web menyimpan status `menunggu_verifikasi` dan menulis satu baris antrean per admin penerima.
3. Worker mengambil antrean. Cron menjalankannya tiap menit, dan web juga memicunya langsung setelah upload.
4. Worker mengirim foto dan tombol ke Telegram.
5. Admin menerima pesan.
6. Admin menekan tombol. Telegram memanggil webhook, web memverifikasi pesanan.

Tabel baru

Tabel	Kolom utama	Fungsi
<code>telegram_sessions</code>	<code>telegram_user_id</code> , <code>chat_id</code> , <code>admin_id</code> , <code>notify</code> , <code>last_active_at</code> , <code>expires_at</code>	Sesi login bot
<code>telegram_login_attempts</code>	<code>telegram_user_id</code> , <code>attempted_at</code> , <code>success</code>	Batas gagal login

Tabel	Kolom utama	Fungsi
telegram_outbox	chat_id, order_id, type, payload, attempts, sent_message_id, status	Antrean notifikasi dan retry
telegram_updates	update_id (unique), received_at	Cegah update ganda dari Telegram

Komponen kode baru

- `app/Controllers/TelegramWebhookController.php` : satu endpoint `POST /telegram/webhook`, di luar filter `csrf` dan `maintenance`.
- `app/Libraries/TelegramBot.php` : klien Bot API (`sendMessage`, `sendPhoto`, `sendDocument`, `editMessageText`, `answerCallbackQuery`).
- `app/Libraries/Telegram/Commands/*` : satu class per command, dengan pengecekan role di satu tempat.
- `app/Commands/TelegramOutbox.php` : `php spark telegram:outbox` untuk kirim dan retry antrean.
- `app/Libraries/ReportExporter.php` : logika export Excel/PDF dipindah dari controller agar web dan bot memakai kode yang sama.

Kode yang dipakai ulang: `OrderModel::verifyPayment`, `rejectPayment`, `complete`, `ReportModel`, `StoreSettingModel`, helper `log_activity`, dan `IntegrationSettings` untuk menyimpan token bot terenkripsi.

Keamanan dan Privasi

- **Verifikasi webhook:** setiap request wajib membawa header `X-Telegram-Bot-API-Secret-Token` yang cocok. Request tanpa header ditolak 403.
- **Token bot:** disimpan terenkripsi lewat `IntegrationSettings`, tidak pernah tampil utuh di panel.
- **Password:** bot menghapus pesan password setelah dibaca. Password tidak ditulis ke log. Pertimbangkan Telegram Login Widget atau kode sekali pakai dari panel web sebagai alternatif (lihat pertanyaan terbuka).
- **Otorisasi per aksi:** setiap command dan setiap tombol mengecek ulang sesi dan role di server. Data tombol (`callback_data`) hanya berisi ID pesanan dan aksi, bukan hak akses.
- **Chat pribadi saja:** bot mengabaikan command admin dari grup, agar data customer tidak bocor ke anggota grup.

- **Bukti bayar:** dikirim sebagai file dari server ke Telegram. Tidak ada URL publik baru ke folder `writable/`.
- **Data customer:** ID game dan nomor WhatsApp tampil lengkap hanya untuk admin yang login. Tamu tidak bisa mengakses data pesanan apa pun.
- **Rate limit:** webhook memakai `RateLimitFilter` per `telegram_user_id`. Maksimal 30 command per menit per user.
- **Jejak audit:** login, logout, verifikasi, tolak, selesai, unduh laporan, buka dan tutup toko tercatat di `activity_logs` dengan sumber `telegram`.
- **Idempotensi:** `update_id` Telegram disimpan unik, jadi update yang dikirim ulang Telegram tidak diproses dua kali.

Non-Fungsional, Rilis, dan Risiko

Kebutuhan non-fungsional

- Webhook membalas Telegram dalam < 2 detik. Pekerjaan berat (export laporan, kirim foto) masuk antrean.
- Bahasa bot: Bahasa Indonesia, nominal dalam format `Rp 150.000`.
- Kegagalan Telegram tidak boleh menggagalkan checkout, upload bukti, atau verifikasi di web.
- Setiap command punya feature test PHPUnit dengan payload Telegram palsu.

Rencana rilis

1. Fase 1: login, logout, `/status`, `/buka`, `/tutup`. Fondasi sesi dan webhook.
2. Fase 2: notifikasi pesanan dengan bukti bayar dan antrean.
3. Fase 3: verifikasi, tolak, dan selesai lewat tombol.
4. Fase 4: `/laporan` Excel dan PDF.

Setiap fase rilis ke owner dulu selama 3 hari, lalu ke semua admin.

Risiko

Risiko	Dampak	Mitigasi
Shared hosting tidak punya cron per menit	Notifikasi telat	Picu worker langsung setelah upload, cron sebagai cadangan
HP admin hilang dengan sesi aktif	Orang lain bisa verifikasi	Owner mencabut sesi lewat <code>/sesi</code> atau panel web
Route export Excel/PDF di web belum ada	F2 tidak bisa memakai ulang kode	Buat <code>ReportExporter</code> lebih dulu (lihat catatan repo)

Risiko	Dampak	Mitigasi
Admin salah tekan Verifikasi	Pesanan diproses tanpa bayar	Tombol konfirmasi kedua untuk Verifikasi

Pertanyaan terbuka

- ☐ Apakah admin biasa boleh `/tutup` dan `/buka`, atau hanya owner? Draf ini mengizinkan keduanya.
- ☐ Tetap login dengan password di chat, atau pakai kode sekali pakai yang dibuat di panel web?
- ☐ Apakah notifikasi WhatsApp Wablas ke admin tetap jalan setelah bot aktif?
- ☐ Apakah bot perlu fitur publik untuk customer, misalnya cek status invoice?

Catatan dari analisis repo yang perlu beres sebelum atau bersama PRD ini:

- `Routes.php` memanggil `ReportController::exportExcel` dan `exportPdf`, tetapi controller hanya punya `exportCsv`. Export web saat ini rusak.
- `VoucherModel::commitReservation` tidak pernah dipanggil. Reservasi voucher dilepas setelah 15 menit walau pesanan sudah dibayar, jadi kuota voucher tidak berkurang.
- Form checkout tidak mengirim `idempotency_token`, jadi proteksi double-submit tidak aktif.
- Route `metode-bayar` tidak memakai filter `role:owner`, padahal README menyebutnya akses owner.